

TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

Мульти-брендовая фишинговая операция, раскрытая публичным облачным бакетом

Фишинг • Кража учётных данных • Публичный бакет • BEC • Открытый редирект

Параметр	Значение
Дата инцидента	2026-08-06 – 2026-08-10 (активно); Оператор А — с 2026-07-21
Дата отчёта	2026-08-10
Классификация	Кредофишинг / commodity-фишинг
Уровень угрозы	ВЫСОКИЙ
Операторы	Три параллельных (А: верификация почты; В: фабрика китов; С: BEC под DocuSign)
Источник	Мониторинг входящей почты (агрегированная телеметрия) + анализ открытого бакета

1. Краткое заключение

При мониторинге входящей почты организации гражданского общества в начале августа 2026 года мы наблюдали три параллельные фишинговые операции. Одна из них раскрыла весь свой инструментарий через публично листящийся бакет Google Cloud Storage (storage.googleapis[.]com/cloakier/), что позволило восстановить работу одного актора, ведущего шесть китов под разными брендами — Webmail/Roundcube, DocuSign, LinkedIn, Microsoft Teams/Zoom, Office 365 Excel и приманку под B2B-закупки — из единого склада, с выводом учётных данных через несколько бэкендов, включая Telegram-бот.

Отчёт сосредоточен на этом операторе (Оператор В) и кратко фиксирует двух других, работавших одновременно: вместе они показывают типовой сценарий commodity-фишинга против небольших организаций — подделать внутренний или доверенный бренд, спрятать нагрузку за доверенной платформой (объектное хранилище, сокращатели ссылок, открытые редиректы на возрастных легитимных доменах) и собирать учётки на ротируемых бэкендах.

Ключевые выводы

- Публичный неаутентифицированный GCS-бакет держал 29 объектов — шесть различных фишинг-китов и их декои.
- Вывод учётных данных использовал не менее четырёх эндпоинтов оператора (две ветки одного домена + два сторонних хоста) и Telegram-бот для доставки в реальном времени.
- Киты используют «доверие к платформе»: хостинг в объектном хранилище, загрузчик через blob:-URL, скрывающий вредоносный источник из адресной строки, и декой-страницы ошибок на IPFS для GET-запросов аналитика.
- Два оператора одновременно били по одной организации: один вёл трёхнедельную кампанию «повторной верификации почты» с выводом учёток на общий form-ID сервиса форм, другой — рассылку под брендом DocuSign со злоупотреблением открытым редиректом на возрастном легитимном домене.
- Практический принцип для защитников: скомпрометированные легитимные сайты и резидентские релеи в этих цепочках — жертвы; блокировать нужно путь URL, а не домен или IP.

2. Оператор В — фабрика мульти-брендовых китов

2.1. Раскрытие

Оператор разместил киты в бакете Google Cloud Storage, оставленном публично листящимся. Анонимный запрос к корню бакета вернул полный список объектов — без аутентификации — раскрыв весь арсенал актора:

Папка	Поддельываемый бренд	Бэкенд вывода учётных данных
nd/	Webmail / DocuSign	ww2.crhamericasmaterial[.]com/nd/2.php
Кит LinkedIn	LinkedIn (кит. локаль)	ww2.crhamericasmaterial[.]com/vicar/submit.php
Кит "Sign-in"	обобщённый SSO	ww2.crhamericasmaterial[.]com/vicar/1.php
Кит Teams	Microsoft Teams / Zoom	clapstickmkt.name[.]ng/rst/1.php + Telegram-бот
expoerr/	Office 365 Excel	stockltd.duckdns[.]org/expo/ali.php (офлайн)
new/	Made-in-China / закупки	не восстановлен (обфускация; загрузчик отсутствует)

Кит DocuSign/Webmail (nd/sonic.html) был доставлен в нашу мониторируемую организацию 2026-08-08 под видом «Action Required: Document Review». Это одна кампания из шести.

2.2. Приёмы обхода

- Доверие к платформе для хостинга. Киты — в Google Cloud Storage; ссылки-посадки завернуты в google.com/url?q=, так как доставка шла через Gmail. Репутационные системы видят только доверенные домены.
- Загрузчик blob:-URL. Свежий кит (обновлён 2026-08-06) читает email жертвы из фрагмента URL, тянет тело страницы, пересобирает в памяти и открывает как blob: — вредоносный хост в адресной строке не виден.
- Декои для аналитика. GET-запросы к живым .php-эндпоинтам уводятся (302) на index.php или на IPFS-страницу ошибки; сбор срабатывает только на POST из кита. Живость эндпоинта не доказывает захвата учёток.
- Вывод в Telegram. Teams-кит дублирует вывод учёток в Telegram-бот помимо PHP-эндпоинта — доставка оператору в реальном времени. (Идентификаторы бота в публичной версии не приводятся.)

2.3. Инфраструктура бэкенда

- crhamericasmaterial[.]com — зарегистрирован 2026-05-08, за Cloudflare, две ветки вывода (/nd/, /vicar/).
- clapstickmkt.name[.]ng — вывод Teams-кита, за Cloudflare.
- stockltd.duckdns[.]org — вывод O365-кита, на момент написания офлайн.
- Домен отправки asemmetric[.]com (A = 45[.]74[.]252[.]189, Valkyrie Hosting) доставил письмо под DocuSign с подделанным внутренним From.

3. Оператор А — устойчивый credphish «повторная верификация почты»

Параллельно и непрерывно (~3 недели, с 2026-07-21 в август) отдельный оператор подделывал внутренний адрес Admin@ организации под предлогом верификации аккаунта и напоминания о пароле. Кит-клон Roundcube крутится на ротации скомпрометированных легитимных WordPress-сайтов и доверенного объектного хранилища и динамически брендируется под жертву — подтягивает логотип цели и скриншот её сайта в фон, email жертвы читается из фрагмента URL.

Все варианты выводят учётки на единый form-ID сервиса форм (эндпоинт Formspark). Это стабильный пивот — тот же идентификатор связывает кампанию с более ранней волной (Compromised-WordPress credential phishing, 2026-07-07). Отправка — с bulletproof-подсети /24 (Pitline Ltd, NL).

Урок: IP-адреса отправки и фронт-хосты ротируются свободно, но form-ID сбора устойчив — отслеживайте идентичность вывода, а не инфраструктуру доставки.

4. Оператор С — BEC под DocuSign через открытый редирект

Третья, кратковременная операция (2026-08-06...08-09) разослала приманку под DocuSign («требуется подпись / платёжная инструкция») по финансовым и административным ящикам организации. Отправитель подделан под dse_na2@docusign[.]net (SPF Fail), вброс напрямую с ротируемых резидентских релейев.

Боевая ссылка вела не на нагрузку, а через открытый редирект на возрастном легитимном сайте (эндпоинт Liferay find_entry с параметром noSuchEntryRedirect= — легитимная функция,

используемая как редиректор) на скомпрометированный WordPress. Первый хоп — домен 1998 года за Cloudflare, поэтому репутационные фильтры его пропускают. Финальный кит на момент анализа снят или клоачит, поэтому кража учётных/платёжных данных выведена по шаблону, а не наблюдалась напрямую.

5. Рекомендации защитникам

- Взвешивайте результат аутентификации, а не поверхностные признаки. Все три операции опирались на подделку (SPF fail/softfail, отсутствие DKIM, невыровненный DMARC).
- Блокируйте пути URL, а не домены жертв. Скомпрометированные легитимные сайты и резидентские релеи проходят через все цепочки.
- Считайте ссылки на доверенные платформы полноценными фишинг-хостами. Объектное хранилище, сокращатели, открытые редиректы на возрастных доменах — текущая норма.
- Пивотьте по идентичности вывода. Form-ID сервисов форм, идентификаторы Telegram-ботов и пути бэкендов устойчивее IP отправки.
- Проверьте собственные облачные бакеты. Весь инструментарий Оператора В раскрыт одним публично листящимся бакетом.

6. Индикаторы компрометации (defanged)

6.1. Оператор В — фабрика китов

Type	Value
URL (staging)	hxxps://storage.googleapis[.]com/cloakier/
URL (exfil)	hxxps://ww2.crhamericasmaterial[.]com/nd/2.php
URL (exfil)	hxxps://ww2.crhamericasmaterial[.]com/vicar/submit.php
URL (exfil)	hxxps://ww2.crhamericasmaterial[.]com/vicar/1.php
URL (exfil)	hxxps://clapstickmkt.name[.]ng/rst/1.php
URL (exfil)	hxxps://stockltd.duckdns[.]org/expo/ali.php (offline)
Domain	crhamericasmaterial[.]com
Domain	acemmetric[.]com
IP (sender)	45[.]74[.]252[.]189

6.2. Оператор А — верификация почты

Type	Value
URL (exfil)	hxxps://submit-form[.]com/4FJePSjAq (form ID — pivot; shared service, do not block domain)
URL (kit path)	hxxps://habitatcyprus[.]com/wp-includes/build/ (compromised site — block path only)
Host (kit)	emailportalverify-gg218lvp3x.edgeone[.]app
IP (sender)	77[.]83[.]39[.]10, .14, .15, .17, .24 (Pitline Ltd /24, NL)
IP (sender)	198[.]135[.]51[.]150

--	--

6.3. Оператор С — BEC под DocuSign

Type	Value
URL (open-redirect hop)	hxxps://members.universityclubofstpaul[.]com/c/blogs/find_entry?...noSuchEntryRedirect=... (aged legit domain — block path only)
URL (compromised WP)	hxxps://kingcrossingbookclub[.]org/Goodsdys/redirect.php (compromised site — block path only)
Spoofed sender	dse_na2@docusign[.]net (real brand address — do not block)
IP (residential relay)	103[.]174[.]214[.]188, 186[.]19[.]160[.]163 (compromised hosts — do not block)

7. MITRE ATT&CK

T1566.002 (Spearphishing Link), T1656 (Impersonation), T1585.002 (Establish Accounts: Email), T1584.006 (Compromise Infrastructure), T1608.005 (Stage Capabilities: Link Target), T1102 (Web Service).

TLP:CLEAR — Этот документ может распространяться без ограничений.